

Benchmark - Developing Enterprise Framework for a Security Program

Grand Canyon University

ITT-430 IT Security Driven Systems Administration

Professor Christopher Gentry

Liela Pressley

January 3, 2025

Applicable U.S. federal laws and policies

Pike's Peak Health Care [PPHC] requires unique cybersecurity standards that adheres to NIST as well as guidelines that directly apply to PHI management. Some applicable US Federal laws and policies include the following: HIPAA, PCI DSS, Healthcare Cybersecurity Act , NIST 800-53, and USA PATRIOT Act for medical records. In addition, SOX ACt is not limited to public companies but it also applies to healthcare corporations who are publicly trading on the stock exchange. It is imperative that healthcare organizations such as PPHC maintain compliance with each of these federal regulations as they ensure that data is protected, has integrity and is secured (in transit, at rest and when stored). HIPAA provides security standards such as technical safeguards which are policy and procedures that protect electronic PHI and control access to it. PCI DSS provides a framework of requirements to secure all payment cards account data being stored, in transit or processed via payment processors, acquires, issuers, etc. Since PPHC will have payment card data processing capabilities for co-pays, payment plans and internal payments for funding; PCI DSS is required(*PCI DSS Compliance: 12 Requirements (V4.0) | CrowdStrike*, n.d.). Training on information security is just as important as implementing new processes and protocols as it ensures proper maintenance and minimizes user error; the Healthcare Cybersecurity Act of 2024 requires the Cybersecurity and Infrastructure Security Agency to provide information and training on cybersecurity threats to healthcare providers and reports be made to Congress on the effectiveness of these efforts (*S. 4697, Healthcare Cybersecurity Act of 2024, 2024*).

NIST 800-53 recently updated their guidance for healthcare providers which consist of maintaining CIA of ePHI (patient data) such as prescriptions, lab results, hospital visit records and more. NIST provides guidelines on risk management and security rule that are specific to

healthcare data protection needs (*Boutin, 2023*). The PATRIOT Act is now provisioned to allow the government to seize patient medical records without probable cause or warrant and doctors who violate the order can be fined/prosecuted for obstruction of justice (*Lenzer J. (2006)*).

Compliance and Audit Types

Compliance is an agreement for an organization to demonstrate that the employees agree to comply with policies through act or affirmation. An audit is a verification process that those policies/rules are being followed (compliant to) correctly and that goals determined are being achieved. Internal audits are assessments that are performed regularly by the organization whereas external audits are performed by a party outside of the organization to verify compliance. Within these audits, assessments of adherence to internal controls, specifications and policy standards are performed to ensure that the tasks performed by employees are compliant within the scope of the audit. The audits test the procedures in relevance to each control that is within scope of the audit which includes asking questions of employees about their processes, conducting walkthroughs, inspecting documentation and screenshots of the processes and testing for exceptions to the control.

Compliance

In order to ensure that the organization's cybersecurity posture and compliance management system is consistent; compliance monitoring is implemented. Compliance monitoring is the act of regularly assessing whether the organization is adhering to regulatory requirements which can be organized internally or outsourced, externally. Compliance levels is a measurement system on how well an entity conforms to the requirement starting with low then to medium then to high which can be performed with various representations. Testing for compliance is necessary but is not effective if compliance training is not performed for all

employees within the organization. Compliance training should consist of a clear explanation of the relevant regulations and internal controls that are to be adhered to, the consequences of failing to comply, and the relevance to their job description and the company as a whole.

Audit Process

The audit process requires a designated timeline to accomplish each phase. Starting off for an internal audit, a charter needs to be established which provides the organization with a blueprint for how the audit will operate and to give a clear layout of the IA team's independence, the relevant scopes of the audits that need to be performed, and tasks that need to be completed. The charter provides a mission, international standards of practice, established authority, statements of independence/objectivity, scope of IA activities, responsibilities, and a statement of quality assurance and improvement.

Within the planning phase the auditor must discuss with the client the scopes and objectives of the examination, and evaluate existing controls. Next they will create and provide a planning memo which establishes the auditors who are assigned to the project, the scope and objectives of the audit. After the memo is provided an opening conference which discusses the client's resources, the systems being reviewed, and staff members who are responsible for the actions being reviewed. Prior to starting the audit, it is important to conduct a survey or preliminary review of prior audits or similar audits which can be used as the baseline. Next the auditors are to review the system's internal control structure and evaluate where the highest risks and designs are to be performed which is then provided to the client. The auditors will then provide a PBC listing which is a list of items the auditors need for review such as reports, policies, procedures, layouts, user access logs etc. During the fieldwork/testing/reporting phase, auditor will conduct various tests to ensure that the controls identified are working effectively

and in accordance with the description the client provided. The findings of successes and exceptions will be documented in the audit report. The report will provide specific details of finding that prove out successful alignment with the controls or exceptions that were identified and their level of risk associated with the failed control (*Audit Process | Internal Audit | Chicago State University*, n.d.).

Security Professional's Responsibility

It is every security professional's responsibility to stay up to date on the latest updates on regulations and compliance requirements in relevance to their organization, maintaining compliance within their deliverables and ensuring that system security procedures are aligned with security controls. Information security governance framework provides security professionals a guideline for how to build, maintain, innovate and work with security integrated in their tasks. There are about five key elements that need to be implemented through the governance framework which includes integration of cybersecurity into business strategy and risk management, resilience and incident response, data protection and privacy, adopting emerging technologies and ability to collaborate/share information. These elements are key factors that can be used as a governance checklist to building system security as it allows the organization to assess each standard and procedure to ensure that it meets these requirements, has room for innovation and is risk tolerant (*Cow & Cow, 2024*).

Legal Disputes & Digital Evidence

Using digital evidence in civil cases can be useful such as emails, social media posts or text messages can provide significant information. Unfortunately, these digital evidence pieces can come with the risk of being spoiled, mishandled, modified, and destroyed if handled incorrectly or tampered with. Civil cases required that the specific device or media to be

collected at the company/residence so that it is isolated from the network, cellular or bluetooth connections. Once it is transferred to an accredited digital forensics lab, the evidence can be duplicated into a verified forensic image copy. Civil cases can use digital evidence for defamation, fraud, whistle blowing, industrial espionage and more (*Data, 2024*). For criminal cases, digital evidence can serve down to an image's metadata to indicate where/when a picture was taken, how it was altered or edited, create a timeline for the cases using messages and images and more. Each piece of evidence needs to be extracted properly to ensure that it is permissible in court (*Gonzalez, 2022*).

CIA in Network Security

It is necessary to establish and maintain a strong network security posture. Starting with confidentiality, it is important to ensure data is private and secured from unauthorized users in case of a data breach or leak; this is ensured through encryption, authentication protocols, access controls and secured communication protocols. Integrity is providing assurance that the data is accurate, trustworthy and authentic without risk of unauthorized deletion/modification throughout its cycle of being stored, at rest or transmitted. Maintaining data integrity requires measures that prevent unauthorized modifications, corruption or tampering such as hashing, digital signatures, checksums, and backups. Availability and preventing intrusion disruption is ensuring that users/customers will have access to their data, systems with operational success by having backup systems, recovery strategies, load balancing, failover mechanisms and redundancy.

Least Astonishment, Minimize Trust Surface, and Trust Relationship

In addition to the CIA there are 3 main principles of cybersecurity which include least astonishment, minimize trust surface and trust relationship. Least astonishment is the principle of

designing systems and interfaces so that users can have minimal surprise and high level of expectations of behaviors and actions of the different functions to create an environment where confusion and vulnerabilities can bloom. For example in PPHC, all user interfaces will be simplified as much as possible for all employees with user login events having clear UX/UI design and monitored regularly. Plus, mandatory training on how to navigate all devices relevant to the employee's job description will be implemented regularly plus when updates or changes occur. Minimizing trust surface allows for a manageable risk assessment, better security architecture, reduce attack vectors and increase security posture as a whole by reducing the potential surface area of exploitation, intrusion and breach. PPHC will ensure that all security protocols and controls are adhered to and that network security architecture is built with security as part of the design such as having a zero trust architecture, implementing least privilege and regularly patching and updating systems (*Effective Strategies to Minimize Trust Surface in Cybersecurity: A Comprehensive Guide* | SubRosa, n.d.). Lastly to ensure that PPHC upholds the trust relationship principle, there will be systems that will be connected securely between systems and users on domains to streamline resources through preset guidelines and security protocols. These will allow for user accessibility to information on a trusted domain ensuring availability and integrity of data while remaining secure(*Trust With Caution - Trust Relationship Vulnerabilities + Solutions: A Guide*, n.d.).

Reference

Again, M. C. S. G. (2023, August 21). *Understanding the CIA triad: the foundation of network security*. Medium.

<https://medium.com/@MakeComputerScienceGreatAgain/understanding-the-cia-triad-the-foundation-of-network-security-ceb8d839d7c2#:~:text=The%20integrity%20aspect%20of%20the%20CIA%20Triad,unauthorized%20modifications%2C%20corruption%2C%20or%20tampering%20of%20data>.

Audit Process | Internal Audit | Chicago State University. (n.d.).

<https://www.csu.edu/internalaudit/auditprocess.htm#:~:text=Although%20every%20audit%20process%20is,Report%20and%20Follow%2Dup%20Review>.

Boutin, C. (2023, February 22). *NIST updates guidance for health care cybersecurity*.

NIST. <https://www.nist.gov/news-events/news/2022/07/nist-updates-guidance-health-care-cybersecurity>

Cow, C. T. C., & Cow, C. T. C. (2024, February 8). *Information Security Governance Framework Guide for IT Activities*. Kiteworks | Your Private Content Network.

<https://www.kiteworks.com/cybersecurity-risk-management/information-security-governance-framework-guide-for-it-activities/>

Data, F. (2024, June 12). *Understanding the impact of spoliation of digital evidence in civil cases*. <https://www.linkedin.com/pulse/understanding-impact-spoliation-digital-evidence-civil-2p9ic/>

Effective Strategies to Minimize Trust surface in Cybersecurity: A Comprehensive guide | SubRosa. (n.d.). <https://subrosacyber.com/en/blog/minimize-trust->

guide#:~:text=Trust%20relationships%20are%20fundamental%20in,later%20access%20
without%20re%2Dauthentication.